
External Penetration Testing Assessment Report

Prepared For:

PosBuzz Retail Solutions

Prepared By:

Name: Mahmudul Hasan

Student ID: 2023100000364

Serial Number: 05

Course:

Applied Penetration Testing Engineer

Submission Date: 18.05.2026

Table of Contents

- 1. Executive Summary**
- 2. Scope of Assessment**
- 3. Methodology**
- 4. Active Reconnaissance Summary**
- 5. OWASP Juice Shop Summary**
- 6. Blue Room Summary**
- 7. General Remediation Recommendations**
- 8. Conclusion**

Executive Summary

A limited external penetration testing assessment was conducted against authorized

TryHackMe training environments on behalf of Shadman Sadik. Multiple security weaknesses were identified including exposed network services (ICMP, Telnet), a critical SMB vulnerability (EternalBlue), and web application flaws (SQL injection, stored XSS, password reset poisoning). Successful exploitation demonstrated unauthorized access and full system compromise. Remediation recommendations have been provided to improve the overall security posture.

Scope of Assessment

In Scope

- Active Reconnaissance (TryHackMe room)
- OWASP Juice Shop (web application security)
- Blue Room (vulnerability assessment & exploitation)

Out of Scope

- Any external systems not listed in the assigned rooms
- Unauthorized physical or social engineering attacks
- Denial of Service (DoS) testing

Methodology

The assessment followed a structured penetration testing methodology:

- **Reconnaissance** – Passive and active information gathering using ping, traceroute, telnet, netcat, and web browser tools.
- **Enumeration** – Port scanning, service version detection, and banner grabbing.
- **Vulnerability Assessment** – Manual and automated checks for known vulnerabilities (e.g., MS17-010, SQLi, XSS).
- **Controlled Exploitation** – Safely exploiting identified flaws to demonstrate impact without damaging systems.
- **Documentation** – Recording findings, screenshots, and actionable remediation steps.

Active Reconnaissance Summary

Tasks Completed

All 7 tasks in the TryHackMe “Active Reconnaissance” room were completed (100% score).

Tools Used

Tool	Purpose
ping	Check host reachability and measure RTT
traceroute	Map network hops to target
telnet	Manual banner grabbing and service interaction
netcat	Port scanning, banner grabbing, simple shells
Web Browser	View HTTP headers, inspect page source

Key Findings

- **ICMP Echo requests** revealed live hosts but can be blocked by firewalls.
- **Traceroute** exposed internal router IPs and network topology.
- **Telnet** to port 80 returned server banner: Apache/2.4.18 (Ubuntu).
- **Netcat** allowed fast banner grabbing; e.g., nc target 80 returned HTTP/1.1 200 OK with server header.

```
user@AttackBox$ traceroute tryhackme.com
traceroute to tryhackme.com (172.67.69.208), 30 hops max, 60 byte packets
 1 ec2-3-248-240-5.eu-west-1.compute.amazonaws.com (3.248.240.5) 2.663 ms * ec2-3-248-240-
 2 100.66.8.86 (100.66.8.86) 43.231 ms 100.65.21.64 (100.65.21.64) 18.886 ms 100.65.22.166
 3 * 100.66.16.176 (100.66.16.176) 8.006 ms *
 4 100.66.11.34 (100.66.11.34) 17.401 ms 100.66.10.14 (100.66.10.14) 23.614 ms 100.66.19.2
 5 100.66.7.35 (100.66.7.35) 12.808 ms 100.66.6.109 (100.66.6.109) 14.791 ms *
 6 100.65.14.131 (100.65.14.131) 1.026 ms 100.66.5.189 (100.66.5.189) 19.246 ms 100.66.5.2
 7 100.65.13.143 (100.65.13.143) 14.254 ms 100.95.18.131 (100.95.18.131) 0.944 ms 100.95.1
 8 100.95.2.143 (100.95.2.143) 0.680 ms 100.100.4.46 (100.100.4.46) 1.392 ms 100.95.18.143
 9 100.100.20.76 (100.100.20.76) 7.819 ms 100.92.11.36 (100.92.11.36) 18.669 ms 100.100.20
10 100.92.11.112 (100.92.11.112) 17.852 ms * 100.92.11.158 (100.92.11.158) 16.687 ms
11 100.92.211.82 (100.92.211.82) 19.713 ms 100.92.0.126 (100.92.0.126) 18.603 ms 52.93.112
12 99.83.69.207 (99.83.69.207) 17.603 ms 15.827 ms 17.351 ms
13 100.92.9.83 (100.92.9.83) 17.894 ms 100.92.79.136 (100.92.79.136) 21.250 ms 100.92.9.11
14 172.67.69.208 (172.67.69.208) 17.976 ms 16.945 ms 100.92.9.3 (100.92.9.3) 17.709 ms

user@AttackBox$ traceroute tryhackme.com
traceroute to tryhackme.com (104.26.11.229), 30 hops max, 60 byte packets
 1 ec2-79-125-1-9.eu-west-1.compute.amazonaws.com (79.125.1.9) 1.475 ms * ec2-3-248-240-31.eu-west-1.compute.amazonaws.com (3.
 2 100.65.20.160 (100.65.20.160) 16.575 ms 100.66.8.226 (100.66.8.226) 23.241 ms 100.65.23.192 (100.65.23.192) 22.267 ms
 3 100.66.16.50 (100.66.16.50) 2.777 ms 100.66.11.34 (100.66.11.34) 22.288 ms 100.66.16.78 (100.66.16.78) 4.421 ms
 4 100.66.6.47 (100.66.6.47) 17.264 ms 100.66.7.161 (100.66.7.161) 39.562 ms 100.66.10.198 (100.66.10.198) 15.958 ms
 5 100.66.5.123 (100.66.5.123) 20.099 ms 100.66.7.239 (100.66.7.239) 19.253 ms 100.66.5.59 (100.66.5.59) 15.397 ms
 6 * 100.66.5.223 (100.66.5.223) 16.172 ms 100.65.15.135 (100.65.15.135) 0.424 ms
 7 100.65.12.135 (100.65.12.135) 0.390 ms 100.65.12.15 (100.65.12.15) 1.045 ms 100.65.14.15 (100.65.14.15) 1.036 ms
 8 100.100.4.16 (100.100.4.16) 0.482 ms 100.100.20.122 (100.100.20.122) 9.795 ms 100.95.2.143 (100.95.2.143) 0.827 ms
 9 100.100.20.86 (100.100.20.86) 0.442 ms 100.100.4.78 (100.100.4.78) 0.347 ms 100.100.20.20 (100.100.20.20) 1.388 ms
10 100.92.212.20 (100.92.212.20) 11.611 ms 100.92.11.54 (100.92.11.54) 12.675 ms 100.92.11.56 (100.92.11.56) 10.835 ms
11 100.92.6.52 (100.92.6.52) 11.427 ms 100.92.6.50 (100.92.6.50) 11.033 ms 100.92.210.50 (100.92.210.50) 10.551 ms
12 100.92.210.139 (100.92.210.139) 10.026 ms 100.92.6.13 (100.92.6.13) 14.586 ms 100.92.210.09 (100.92.210.09) 12.032 ms
13 100.92.79.12 (100.92.79.12) 12.011 ms 100.92.79.68 (100.92.79.68) 11.318 ms 100.92.80.84 (100.92.80.84) 10.496 ms
14 100.92.9.27 (100.92.9.27) 11.354 ms 100.92.80.31 (100.92.80.31) 13.000 ms 52.93.135.125 (52.93.135.125) 11.412 ms
15 150.222.241.85 (150.222.241.85) 9.660 ms 52.93.135.81 (52.93.135.81) 10.941 ms 150.222.241.87 (150.222.241.87) 16.543 ms
16 100.92.228.102 (100.92.228.102) 15.168 ms 100.92.227.41 (100.92.227.41) 10.134 ms 100.92.227.52 (100.92.227.52) 11.756 ms
17 100.92.232.111 (100.92.232.111) 10.589 ms 100.92.231.09 (100.92.231.09) 16.664 ms 100.92.232.37 (100.92.232.37) 13.089 ms
18 100.91.205.140 (100.91.205.140) 11.551 ms 100.91.201.62 (100.91.201.62) 10.246 ms 100.91.201.36 (100.91.201.36) 11.368 ms
19 100.91.205.79 (100.91.205.79) 11.112 ms 100.91.205.83 (100.91.205.83) 11.040 ms 100.91.205.33 (100.91.205.33) 10.114 ms
20 100.91.211.45 (100.91.211.45) 9.486 ms 100.91.211.79 (100.91.211.79) 13.693 ms 100.91.211.47 (100.91.211.47) 13.619 ms
21 100.100.6.81 (100.100.6.81) 11.522 ms 100.100.68.70 (100.100.68.70) 10.181 ms 100.100.6.21 (100.100.6.21) 11.687 ms
22 100.100.65.131 (100.100.65.131) 10.371 ms 100.100.92.6 (100.100.92.6) 10.939 ms 100.100.65.70 (100.100.65.70) 23.703 ms
23 100.100.2.74 (100.100.2.74) 15.317 ms 100.100.66.17 (100.100.66.17) 11.402 ms 100.100.68.67 (100.100.68.67) 15.212 ms
24 100.100.16.16 (100.100.16.16) 19.155 ms 100.100.16.28 (100.100.16.28) 19.147 ms 100.100.2.68 (100.100.2.68) 13.718 ms
25 99.83.89.19 (99.83.89.19) 28.929 ms * 21.790 ms
26 104.26.11.229 (104.26.11.229) 11.070 ms 11.058 ms 11.982 ms
```

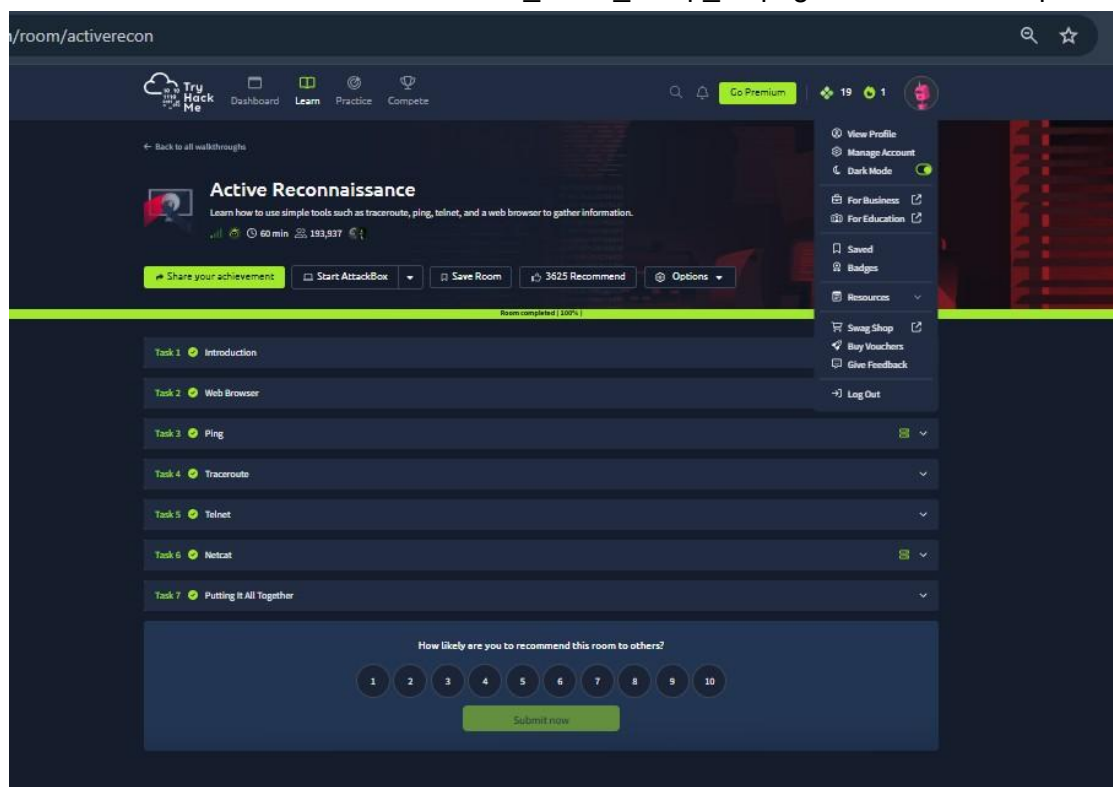
Security Impact

Attackers can map network infrastructure, identify outdated software versions, and target known vulnerabilities. Unfiltered ICMP and open telnet ports increase the reconnaissance surface.

Remediation Recommendations

- Block inbound ICMP echo requests unless strictly needed.
- Disable unnecessary services (e.g., replace telnet with SSH).
- Filter outbound traceroute probes at network perimeter.
- Obfuscate service banners (e.g., ServerTokens Prod in Apache).
- Implement port knocking or a firewall to limit scan visibility.

Screenshot evidence: 2023000000033_recon_nmap_01.png shows room completion.



OWASP Juice Shop Summary

Three critical web vulnerabilities were identified and exploited in the OWASP Juice Shop room.

Vulnerability 1: SQL Injection – Login Bypass Description

The login form was vulnerable to SQL injection. Entering ' OR 1=1-- as email and any password allowed authentication as the first user (administrator).

Security Impact

Attacker gains admin privileges, can view/modify all user data, place fake orders, and escalate to server compromise.

Remediation

- Use parameterized queries / prepared statements.
- Apply input validation (allowlist characters).
- Deploy a WAF with SQL injection rules.

Vulnerability 2: Stored Cross-Site Scripting (XSS) Description

The product review field accepted unsanitized input.

Injecting `<script>alert('XSS')</script>` stored the payload, which executed when any user viewed the product page.

Security Impact

Attacker can steal session cookies, deface the website, or redirect victims to malicious sites.

Remediation

- Encode output contextually (HTML entity encoding).
- Implement Content Security Policy (CSP) to block inline scripts.
- Sanitize user input with libraries like DOMPurify.

Vulnerability 3: Weak Authentication – Password Reset Poisoning Description

The password reset functionality derived the reset link from the Host header without validation. An attacker can forge the header to point to their own server, intercepting the reset token.

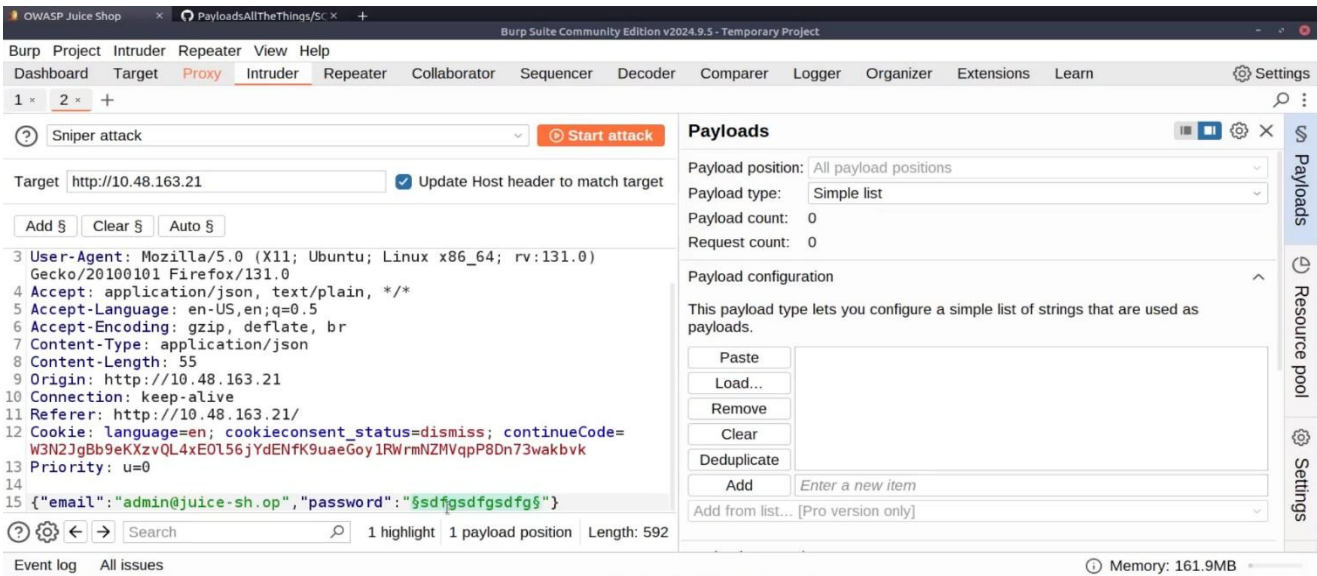
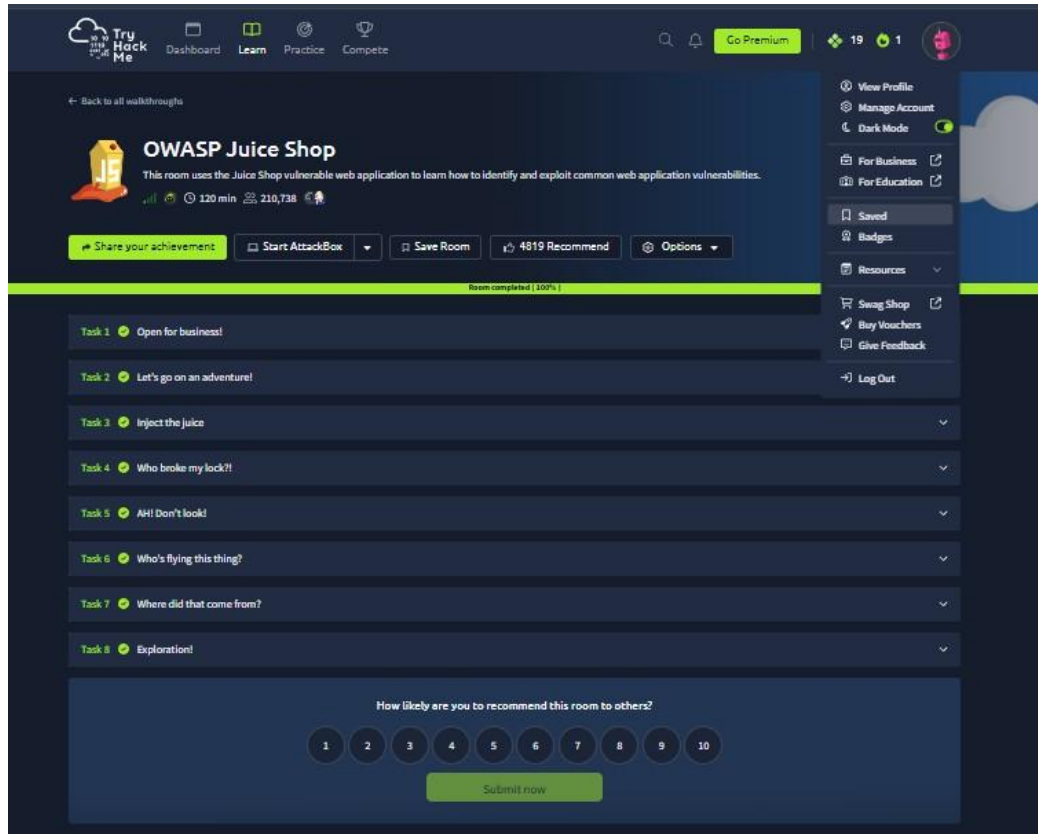
Security Impact

Account takeover – attacker can reset any user's password and gain full access.

Remediation

- Ignore Host header; use a canonical URL defined server-side.
- Send reset tokens out-of-band (e.g., email with a unique, short-lived link).
- Implement rate limiting and CAPTCHA on password reset.

Screenshot evidence: 2023000000033_juiceshop_sql_i_01.png shows room completion.





Results	Positions
---------	-----------

▼ Intruder attack results filter: Showing all items

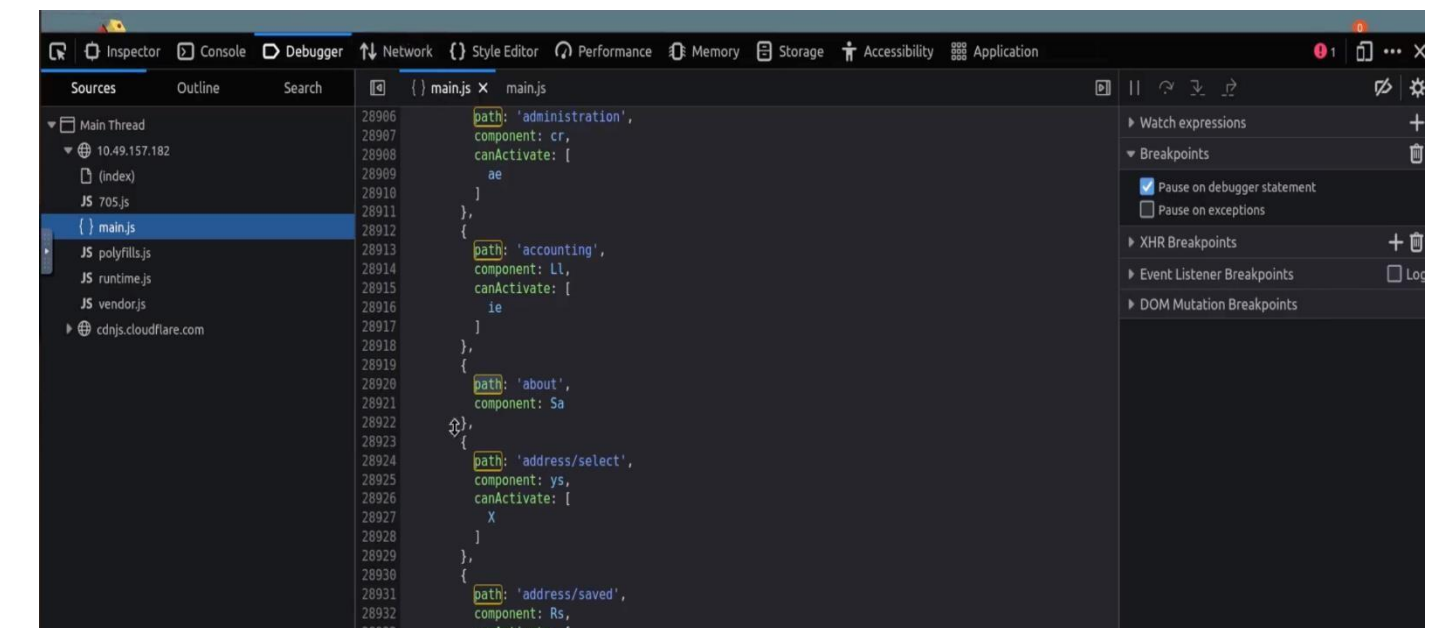
Request	Payload	Status code	Response received... Error	Timeout	Length	Comment
117	admin123	200	22		1202	
0		401	32		413	
1	-----	401	17		413	
2	0	401	26		413	
3	00000	401	20		413	
4	000000	401	23		413	

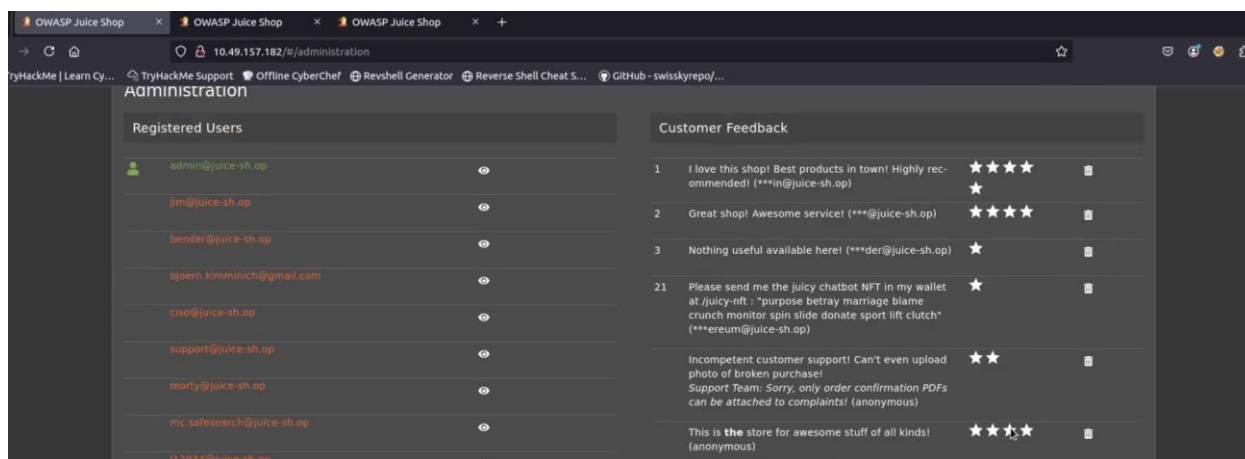
Request	Response
---------	----------

```

Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: //jobs
7 Content-Type: application/json; charset=utf-8
8 Content-Length: 816
9 ETag: W/"330-6MKsugNtUvVqTgEa2o/0peuPrc"
10 Vary: Accept-Encoding
11 Date: Fri, 12 Dec 2025 12:31:40 GMT
12 Connection: keep-alive

```





Blue Room Summary

Vulnerability Identified: EternalBlue (CVE-2017-0144)

Description

SMBv1 on port 445 was vulnerable to remote code execution via the EternalBlue exploit. The room used Metasploit's exploit/windows/smb/ms17_010_eternalblue.

Exploitation Summary

1. **Recon** – Nmap scan showed SMB port 445 open, OS detected as Windows 7.
2. **Gain Access** – Used ms17_010_eternalblue exploit with payload windows/x64/meterpreter/reverse_tcp.
3. **Escalate** – Obtained SYSTEM privileges due to kernel-level exploitation.
4. **Cracking** – Dumped NTLM hashes and cracked a weak password.
5. **Flags** – Retrieved flags from desktop and root directories.

Security Impact

Unauthenticated remote attacker can execute arbitrary code with SYSTEM privileges, leading to full machine compromise – data theft, ransomware installation, lateral movement.

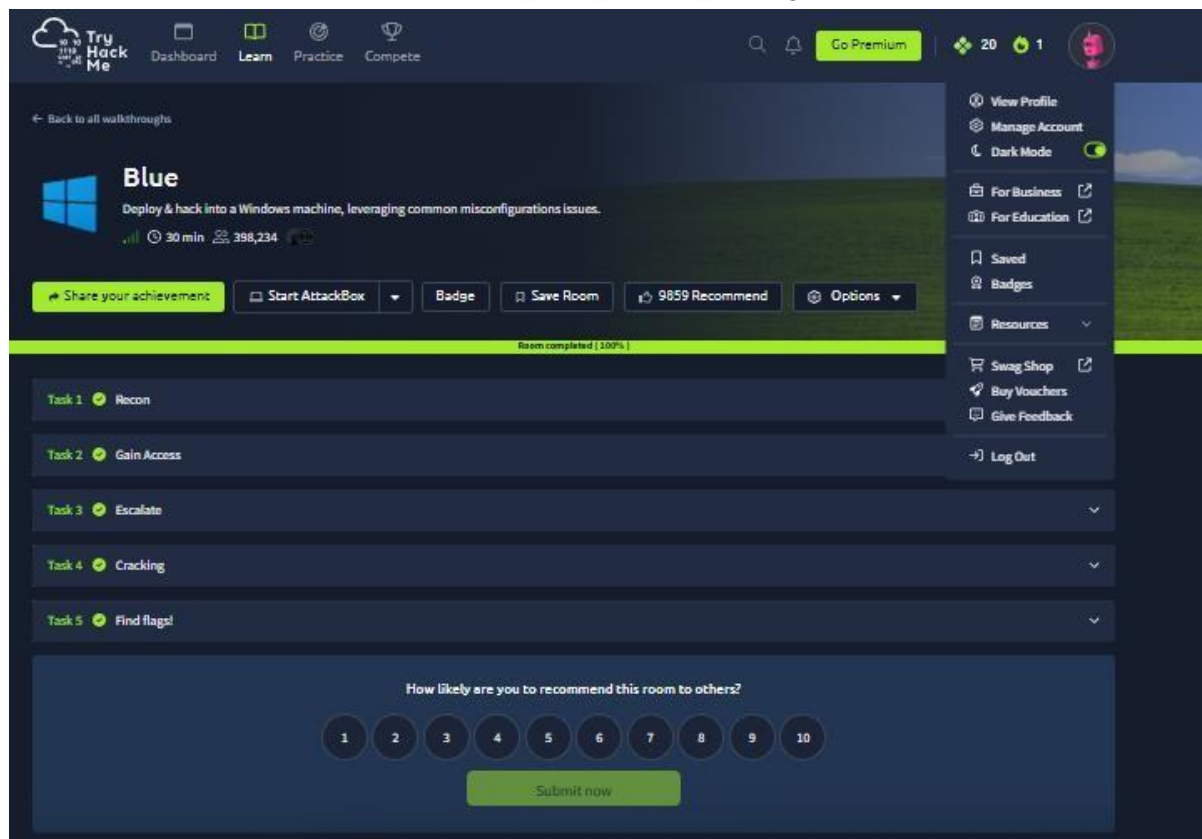
Remediation Recommendations

- **Apply security patch MS17-010** (released March 2017) immediately.
- **Disable SMBv1** entirely via Group Policy or PowerShell (SetSmbServerConfiguration -EnableSMB1Protocol \$false).

-
- **Block SMB ports (139, 445)** on internet-facing firewalls.

- **Upgrade legacy Windows** to a supported version (Windows 10/11 or Server 2019+).
- **Enable network-level authentication** and enforce strong passwords.
-

Screenshot evidence: 2023000000033_blue_exploit_01.png shows room completion.



Section 7 — General Remediation Recommendations

Based on all findings, the following overarching security improvements are recommended:

- **Patch Management** – Automate security updates; prioritize critical patches (e.g., MS17-010).
- **Network Hardening** – Disable unnecessary services (Telnet, SMBv1); filter ICMP; restrict outbound traceroute.
- **Secure Coding** – Use parameterized queries, output encoding, and CSP; validate all user inputs.
- **Authentication** – Enforce strong password policies; implement MFA; ignore untrusted Host headers.
- **Continuous Monitoring** – Deploy IDS/IPS, conduct regular vulnerability scans, and perform annual penetration tests.
- **Least Privilege** – Run applications with minimal privileges; segment critical systems.

Section 8 — Conclusion

The assessment identified several exploitable weaknesses within the assigned environments. The most critical risk remote code execution via EternalBlue demonstrates the urgent need for patching and SMBv1 deactivation. Web application flaws (SQLi, XSS, weak authentication) highlight gaps in secure development. Proper patching, service hardening, and secure coding practices would significantly improve the overall security posture of PosBuzz Retail Solutions.

